

UNIT-1

INTRODUCTION TO SECURITY MECHANISMS

1.1 VARIOUS SECURITY TERMS

1.1.1 Introduction

Computer data often travels from one computer to another, leaving the safety of its protected physical surroundings. Once the data is out of hand, people with bad intentions could modify or forge your data, either for amusement or for their benefit.

In many cases information is sensitive so we need to take care that only authorized parties can get that data. For its maintenance, we require some mechanism or physical device which ensures that it is safe. Such a mechanism is known as a **Security System**.

Computer Security: The generic name for the collection of tools designed to protect data and prevent hackers is Computer Security.

Network Security: Network Security refers to the measures taken by any enterprise or organization to secure its computer network and data using both hardware and software systems. Network security measures are needed to protect data during their transmission.

Internet Security: Internet security refers to security designed to protect systems and the activities of employees and other users while connected to the internet, web browsers, web apps, websites and networks. Internet security solutions protect users and corporate assets from cybersecurity attacks and threats.

Threat: A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Attack: An attack is an information security threat that involves an attempt to obtain, alter, destroy, remove, implant or reveal information without authorized access or permission.

Hacker: A hacker is a person who makes use of a computer system to gain unauthorized access to another system for data or who makes another system unavailable.

1.1.2 Virus

A virus is a type of code that enters the system along with any file or program and carries out malfunctions in the system. The virus-affected program will be a replica of the existing program. They enter the system through any file and when the file runs, parallelly the virus also runs in the background.

There are many ways in which the virus gets into the system. Some of them are through mail attachments, by clicking inappropriate advertisements and by downloading any software or files from unauthorized websites. The main objective of viruses is to spread them along different hosts. They steal the personal data and other credentials of the system. Various types of viruses are explained as follows:

- 1) **Parasitic Virus:** The traditional and still most common form of virus. A parasitic virus attaches itself to executable files and replicates, when the infected program is executed, by finding other executable files to infect.
- 2) **Memory-Resident Virus:** Lodges in main memory as part of a resident system program. From that point on, the virus infects every program that executes.
- 3) **Boot Sector Virus:** Infects a master boot record or boot record and spreads when a system is booted from the disk containing the virus.
- 4) **Stealth Virus:** A form of virus explicitly designed to hide itself from detection by antivirus software.
- 5) **Polymorphic Virus:** A virus that mutates with every infection, making detection by the "signature" of the virus impossible.
- 6) **Metamorphic Virus:** As with a polymorphic virus, a metamorphic virus mutates with every infection. The difference is that a metamorphic virus rewrites itself completely at each iteration, increasing the difficulty of detection. Metamorphic viruses may change their behavior as well as their appearance.

How can a computer be protected from viruses?

- Install an anti-malware program to stop software from installing without your knowledge.
- Never download and install software from the Internet unless you are certain it is from a trusted source.
- Do not open email attachments unless you have scanned them first, even a picture can carry a virus.
- Do not trust cracked or hacked software as they often contain malware or Trojans.
- The most suitable way of making your computer virus-free is by installing an Anti-virus software. Such software helps in removing viruses from the device. It should be kept up to date and should regularly run scans. It can be installed on a computer via two means: Online download, Buying an Anti-virus software, and installing it.

1.1.3 Antivirus

An anti-virus is software that comprises programs or sets of programs that can detect and remove all harmful and malicious software from your device. This anti-virus software is designed in a manner that they can search through the files in a computer and determine the files that are heavy or mildly infected by a virus.

Most antivirus programs nowadays include more than just a virus scanner — they also come with features that add additional protection, like a network firewall, phishing protection, a virtual private network (VPN), a password manager, parental controls, as well as dedicated protections for mobile devices. Following are some of the most commonly used anti-virus software:

- 1) Norton
- 2) Bitdefender
- 3) TotalAV

- 4) McAfee
- 5) Intego
- 6) Malwarebytes
- 7) Norton 360
- 8) Surfshark
- 9) Avira
- 10) Trend Micro

1.1.4 Intruder

An intruder (also called a hacker) is an individual who performs security attacks on another's domain in a networked computing environment. The intruder may attempt to read privileged data (like password cracking), perform unauthorized modification of data or disrupt normal functioning of data. There are three types of intruders:

- 1) **Masquerader:** An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account. The masquerader is likely to be an outsider
- 2) **Misfeasor:** A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges. Misfeasor is an insider.
- 3) **Clandestine User:** An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection. Clandestine users can be either insiders or outsiders.

1.2 SECURITY BASICS

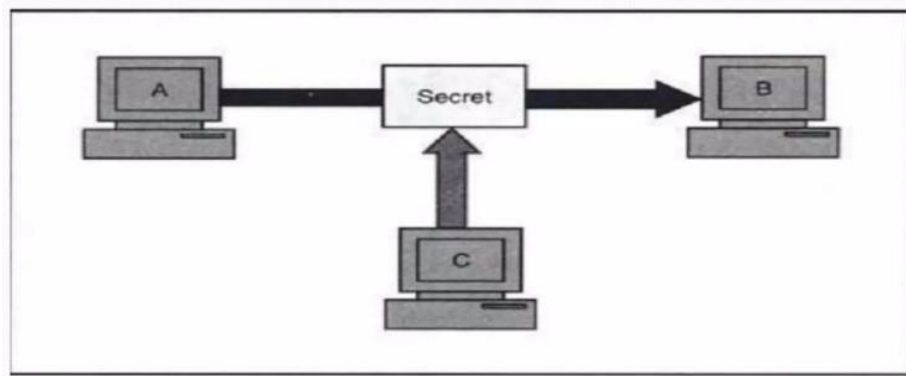
1.2.1 Pillars of Information Security

It is necessary to protect information from being stolen, compromised or attacked. The CIA triad is one of the most important models that is designed to guide policies for information security within an organization. **CIA** stands for **Confidentiality, Integrity and Availability**. These are considered as three pillars of Information Security.

1) Confidentiality:

Confidentiality means that only authorized individuals/systems can view sensitive or classified information. The data being sent over the network should not be accessed by unauthorized individuals. The attacker may try to capture the data using different tools available on the Internet and gain access to your information.

For Example: User A sends a message to User B. Another User C gets access to this message which is not desired and therefore defeats the purpose of confidentiality. This type of attack is called **Interception** and we can say that confidentiality of the message is lost.



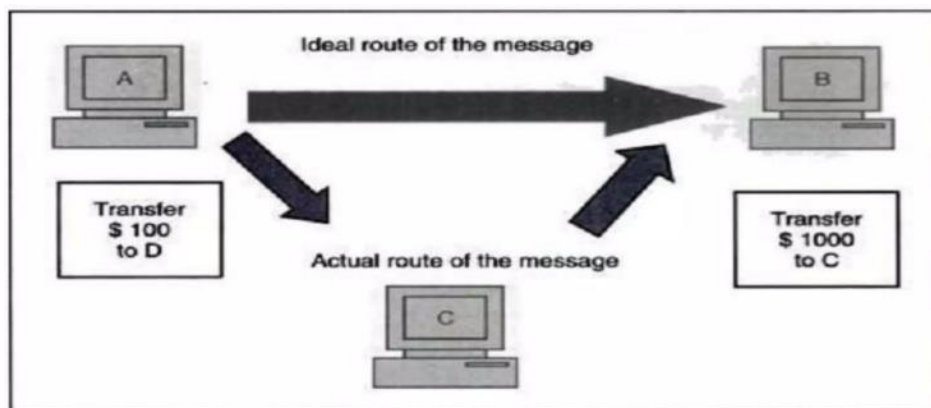
(Figure: Loss of Confidentiality)

To fight against confidentiality breaches, you can classify and label restricted data, enable access control policies, encrypt data, and use multi-factor authentication (MFA) systems. It is also advisable to ensure that all in the organization have the training and knowledge they need to recognize the dangers and avoid them.

2) Integrity:

Integrity makes sure that data has not been modified.

For Example, User A wants to send a message to User B. User C somehow manages to access the data of User A changes its contents and sends a changed message to User B. Users A and B have no idea that the contents of the message were changed. This type of attack is called **Modification** and we can say that the integrity of the message is lost.



(Figure: Loss of Integrity)

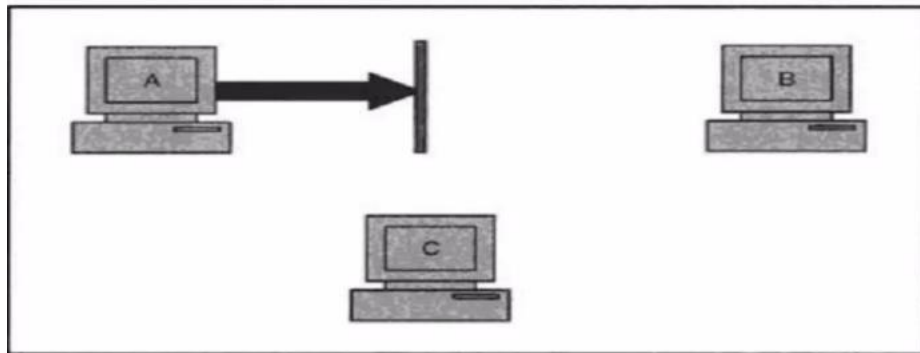
To protect the integrity of your data, you can use hashing, encryption, digital certificates, or digital signatures. For websites, you can employ trustworthy certificate authorities (CAs) that verify the authenticity of your website so visitors know they are getting the site they intended to visit.

3) Availability:

Availability means that the network should be readily available to its users.

This applies to systems and data. To ensure availability, the network administrator should maintain hardware, make regular upgrades, have a plan for fail-over and prevent bottlenecks in a network.

For Example: Due to the intentional actions of unauthorized User C, an authorized User A may not be able to contact server computer B. This type of attack is called **Interruption**. Thus, proper measures should be taken to prevent such attacks.



(Figure: Loss of Availability)

To ensure availability, organizations can use redundant networks, servers and applications. These can be programmed to become available when the primary system has been disrupted or broken. You can also enhance availability by staying on top of upgrades to software packages and security systems. Backups and full disaster recovery plans also help a company regain availability soon after a negative event.

1.2.2 The OSI Security Architecture

The OSI (Open Systems Interconnection) security architecture provides a systematic framework for defining security attacks, security mechanisms and security services. As this architecture was developed as an international standard, various vendors have developed security features for their products and services that relate to this structured definition of services and mechanisms.

- **Security Attacks:** Any action that compromises the security of information owned by an organization.
- **Security Mechanisms:** A process (or a device incorporating such a process) that is designed to detect, prevent or recover from a security attack.
- **Security Services:** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. The services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service.

Security Attacks:

Security Attacks are of two types:

- 1) Passive Attack
- 2) Active Attack

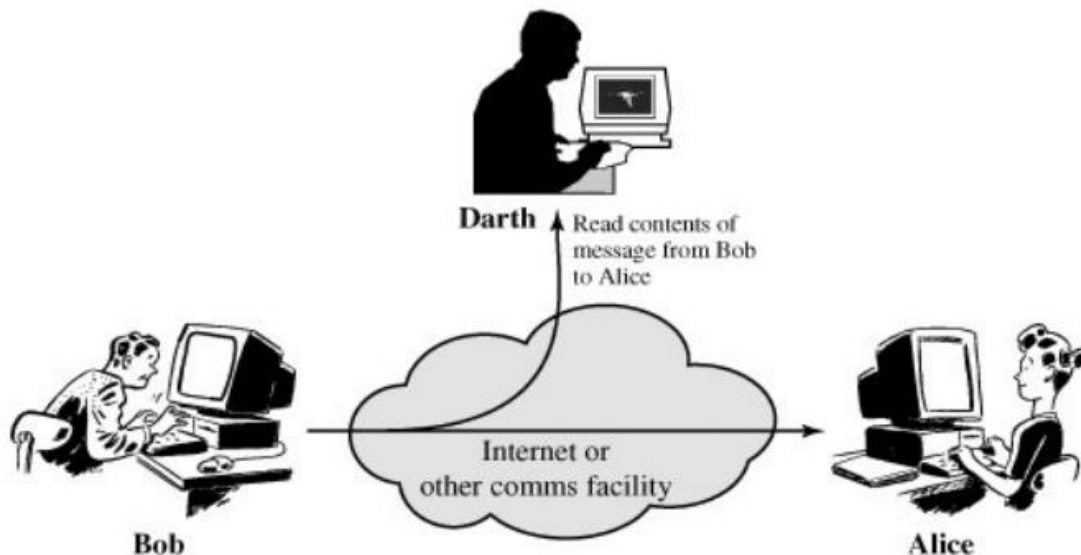
Passive Attack:

In a passive attack, the attacker attempts to learn or make use of information from the system but does not affect system resources. The goal of the opponent/attacker is to obtain information that is transmitted. Passive attacks are of two types:

- a) Release of message contents
- b) Traffic analysis

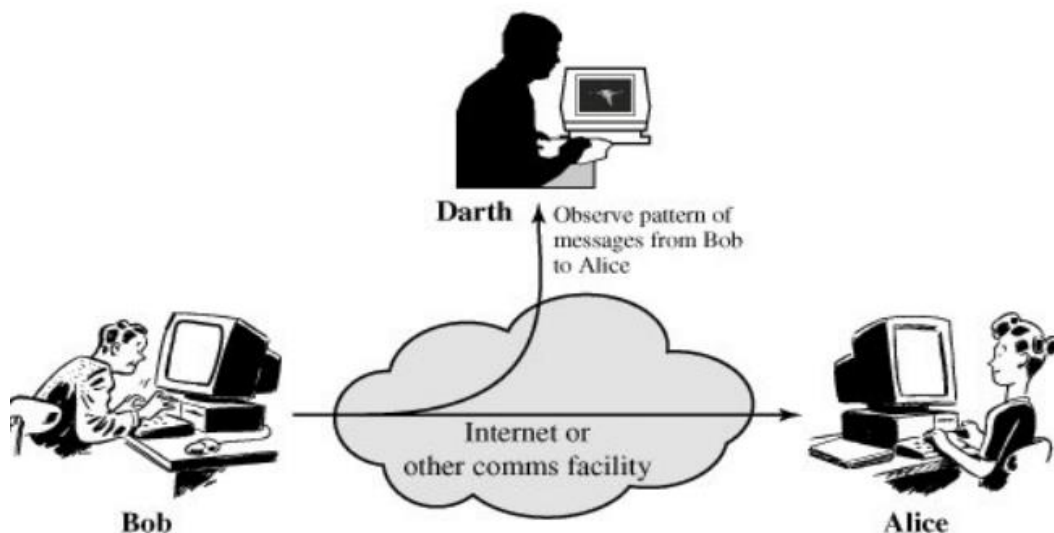
a) Release of Message Contents:

A telephone conversation, an electronic mail message and a transferred file may contain sensitive or confidential information. We would like to prevent an opponent from learning the contents of these transmissions.



b) Traffic Analysis:

Suppose that we had a way of masking the contents of messages or other information traffic so that opponents, even if they captured the message, could not extract the information from the message. The common technique for masking contents is encryption. If we had encryption protection in place, an opponent might still be able to observe the pattern of these messages. The opponent could determine the location and identity of communicating hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of the communication that was taking place.



Passive attacks are very difficult to detect because they do not involve any alteration of the data. Typically, the message traffic is sent and received in a normal fashion and neither the sender nor receiver is aware that a third party has read the messages or observed the traffic pattern. However, it is feasible to prevent the success of these attacks, usually using encryption. Thus, the emphasis in dealing with passive attacks is on prevention rather than detection.

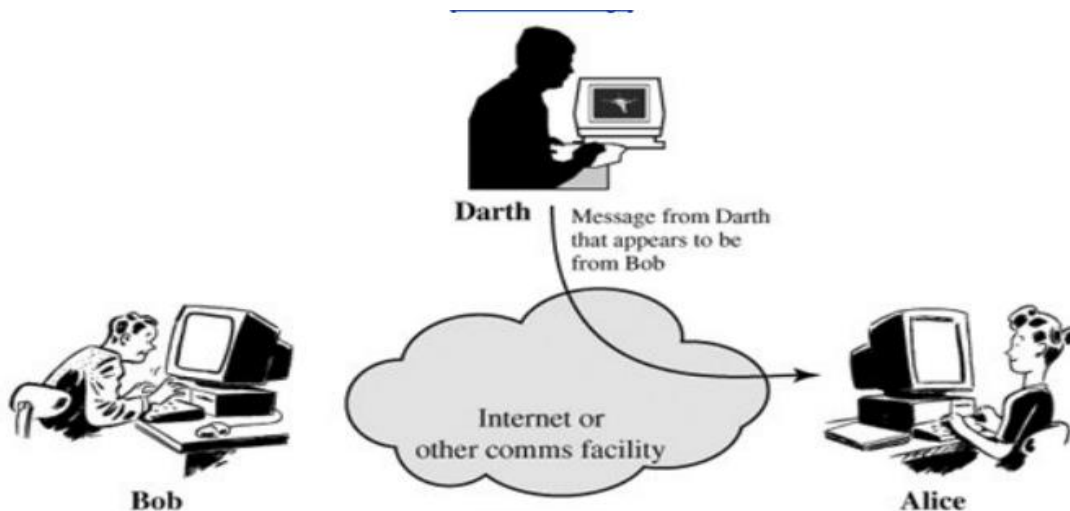
Active Attack:

Active attacks involve some modification of the data stream or the creation of a false stream and can be subdivided into four categories:

- a) Masquerade b) Replay
- c) Modification of Messages d) Denial of Service

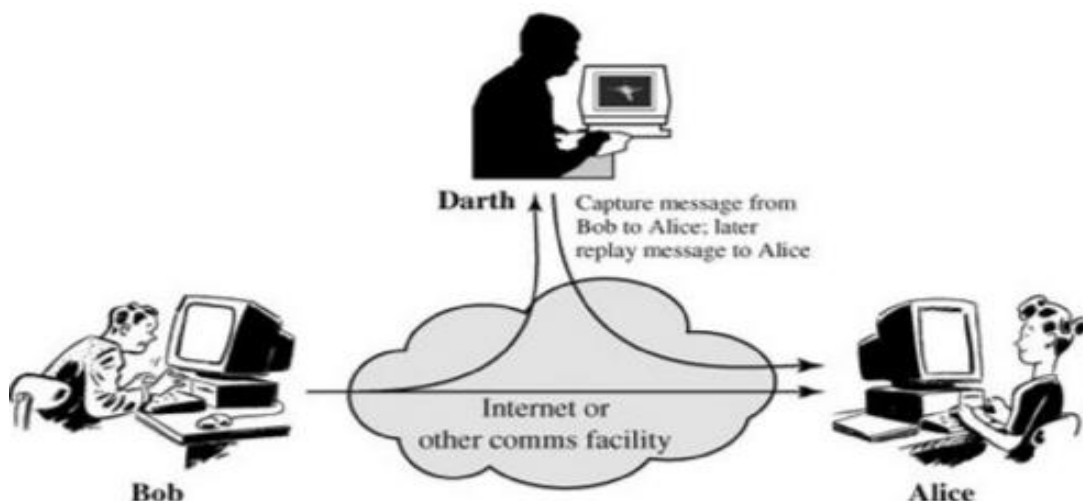
a) Masquerade:

A masquerade takes place when one entity pretends to be a different entity.



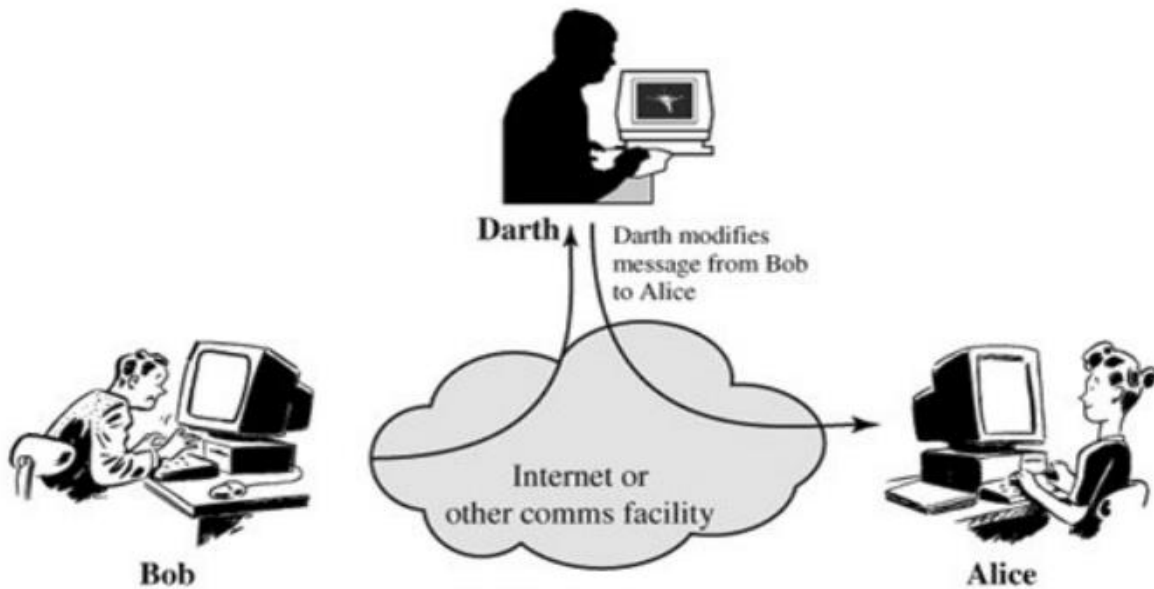
b) Replay:

Replay involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.



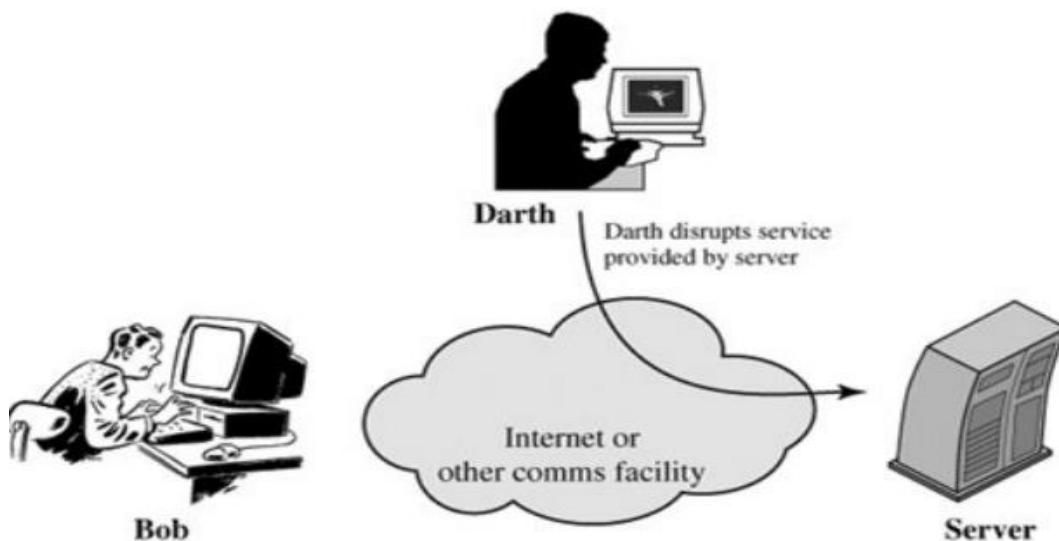
c) Modification of Message:

Modification of messages simply means that some portion of a legitimate message is altered or that messages are delayed or reordered, to produce an unauthorized effect. For example, a message meaning "Allow John Smith to read confidential file accounts" is modified to mean "Allow Fred Brown to read confidential file accounts."



d) Denial of Service:

The denial of service prevents or inhibits the normal use or management of communications facilities. This attack may have a specific target. For example, an entity may suppress all messages directed to a particular destination (e.g., the security audit service). Another form of service denial is the disruption of an entire network, either by disabling the network or by overloading it with messages to degrade performance.



It is quite difficult to prevent active attacks because of the wide variety of potential physical, software and network vulnerabilities. Instead, the goal is to detect active attacks and to recover from any disruption or delays caused by them.

NETWORK SECURITY & MANAGEMENT

Active Attack	Passive Attack
In an active attack, modification in information takes place.	In a passive attack, modification in the information does not take place.
Active Attack is a danger to integrity as well as availability.	Passive Attack is a danger to confidentiality.
In an active attack, attention is on prevention.	In a passive attack, attention is on detection.
Due to active attacks, the execution system is always damaged.	Due to passive attack, there is no harm to the system.
In an active attack, the victim gets informed about the attack.	In a passive attack, the victim does not get informed about the attack.
Active attacks are tough to restrict from entering systems or networks.	A passive attack is easy to prohibit in comparison to an active attack.
The prevention possibility of active attack is high.	The prevention possibility of passive attack is low.
The duration of an active attack is short.	The duration of a passive attack is long.
The purpose of an active attack is to harm the system.	The purpose of a passive attack is to learn the system.

Security Services:

Various security services are explained as follows:

- 1) Confidentiality:** It ensures the protection of data from unauthorized disclosure.
- 2) Authentication:** It is the assurance that the communicating entity is the one that it claims to be.
- 3) Integrity:** It is the assurance that data received are exactly as sent by an authorized entity (i.e., contain no modification, insertion, deletion or replay).
- 4) Non-repudiation:** It protects against denial by one of the entities involved in a communication of having participated in all or part of the communication.
- 5) Access Control:** The prevention of unauthorized use of a resource (i.e., this service controls who can have access to a resource, under what conditions access can occur and what those accessing the resource are allowed to do).
- 6) Availability:** It states that resources/information should be available to authorized parties at all times.

Security Mechanisms:

Security Mechanisms are classified into two types:

- 1) Specific Security Mechanism
- 2) Pervasive Security Mechanism

Specific Security Mechanism

Specific Security Mechanisms may be incorporated into the appropriate protocol layer to provide some of the OSI security services.

- a) **Encipherment:** The use of mathematical algorithms to transform data into a form that is not readily intelligible. The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.
- b) **Digital Signature:** A digital signature is an authentication mechanism that enables the creator of a message to attach a code that acts as a signature.
- c) **Access Control:** A variety of mechanisms that enforce access rights to resources.
- d) **Data Integrity:** A variety of mechanisms used to assure the integrity of a data unit or stream of data units.
- e) **Authentication Exchange:** A mechanism intended to ensure the identity of an entity by means of information exchange.
- f) **Traffic Padding:** The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
- g) **Routing Control:** Enables selection of particular physically secure routes for certain data and allows routing changes, especially when a breach of security is suspected.
- h) **Notarization:** The use of a trusted third party to assure certain properties of a data exchange.

Pervasive Security Mechanism

Pervasive Security Mechanisms are not specific to any particular OSI security service or protocol layer.

- a) **Trusted Functionality:** That which is perceived to be correct with respect to some criteria (e.g., as established by a security policy).
- b) **Security Label:** The marking bound to a resource (which may be a data unit) that names or designates the security attributes of that resource.
- c) **Event Detection:** Detection of security-relevant events.
- d) **Security Audit Trail:** Data collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.
- e) **Security Recovery:** Deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions.

1.3 TYPES OF COMPUTER AND NETWORK ATTACKS

1) Eavesdropping

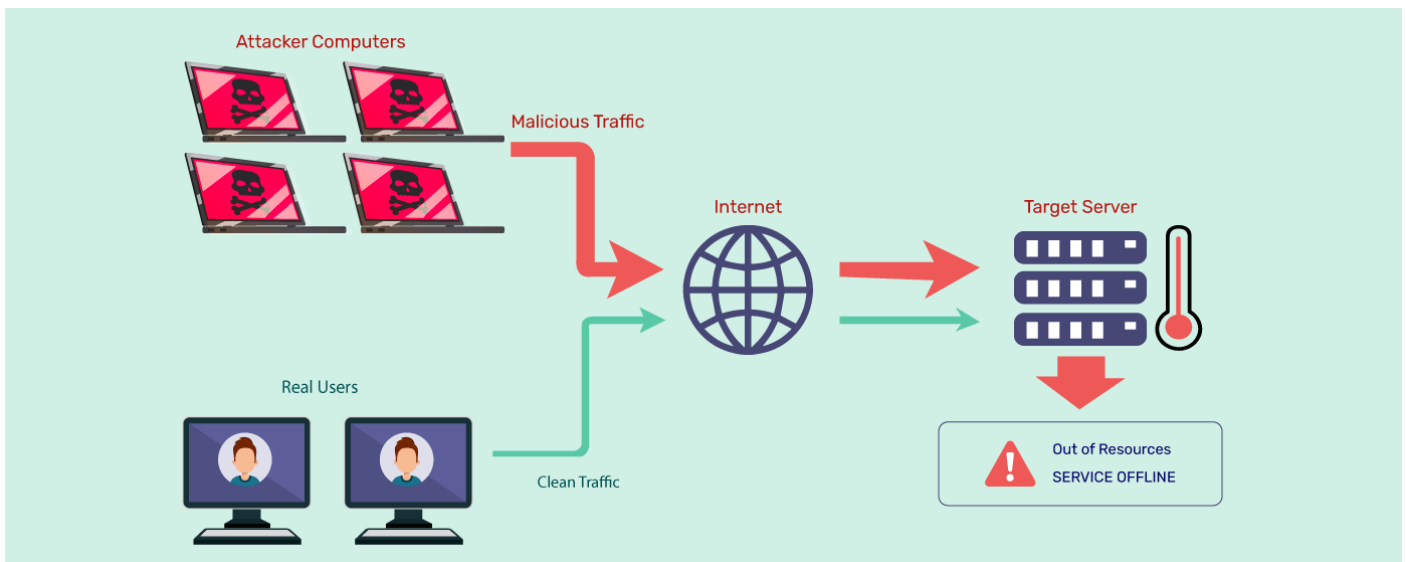
Eavesdropping attacks involve the bad actor intercepting traffic as it is sent through the network. In this way, an attacker can collect usernames, passwords, and other confidential information like credit cards. Eavesdropping can be active or passive. With active eavesdropping, the hacker inserts a piece of software within the network traffic path to collect information that the hacker analyses for useful data. Passive eavesdropping attacks are different in that the hacker “listens in,” or eavesdrops, on the transmissions, looking

for useful data they can steal. Both active and passive eavesdropping are types of MITM attacks. One of the best ways of preventing them is by encrypting your data, which prevents it from being used by a hacker, regardless of whether they use active or passive eavesdropping.

2) Distributed Denial of Service

A distributed denial-of-service (DDoS) attack is a malicious attempt to disrupt the normal traffic of a targeted server, service, or network by overwhelming the target or its surrounding infrastructure with a flood of Internet traffic. DDoS attacks achieve effectiveness by utilizing multiple compromised computer systems as sources of attack traffic. Exploited machines can include computers and other networked resources such as IoT devices. From a high level, a DDoS attack is like an unexpected traffic jam clogging up the highway, preventing regular traffic from arriving at its destination.

DDoS attacks can be segregated by which layer of the Open Systems Interconnection (OSI) model they attack. They are most common in the Network (layer 3), Transport (Layer 4), Presentation (Layer 6) and Application (Layer 7) Layers.



DDoS attacks are carried out with networks of Internet-connected machines. These networks consist of computers and other devices (such as IoT devices) that have been infected with malware, allowing them to be controlled remotely by an attacker. These individual devices are referred to as bots (or zombies), and a group of bots is called a botnet. Once a botnet has been established, the attacker is able to direct an attack by sending remote instructions to each bot. When a victim's server or network is targeted by the botnet, each bot sends requests to the target's IP address, potentially causing the server or network to become overwhelmed, resulting in a denial of service to normal traffic. Because each bot is a legitimate Internet device, separating the attack traffic from normal traffic can be difficult.

3) Malware

Malware is a general term for malicious software. Malware infects a computer and changes how it functions, destroys data, or spies on the user or network traffic as it passes through. Malware can either spread from one device to another or remain in place, only impacting its host device.

Several of the attack methods can involve forms of malware, including MITM attacks, Phishing, Ransomware, SQL injection, Trojan horses, Drive-by attacks, and XSS attacks.

In a malware attack, the software has to be installed on the target device. This requires an action on the part of the user. Therefore, in addition to using firewalls that can detect malware, users should be educated regarding which types of software to avoid, the kinds of links they should verify before clicking, and the emails and attachments they should not engage with.

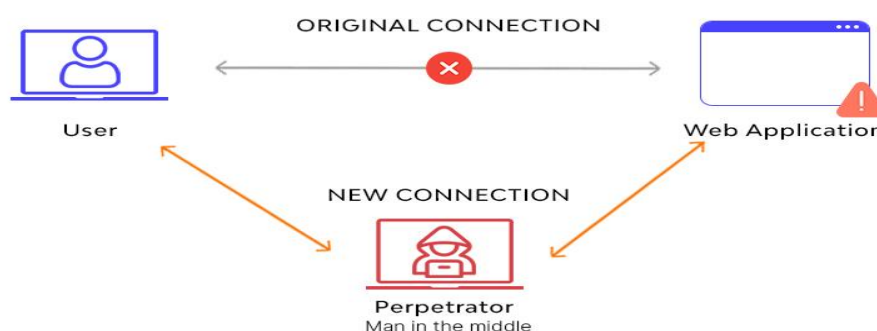
4) Man-in-the-Middle Attack

Man-in-the-middle (MITM) type of cyber-attack refers to breaches in cybersecurity that make it possible for an attacker to eavesdrop on the data sent back and forth between two people, networks, or computers. It is called a “man in the middle” attack because the attacker positions themselves in the “middle” or between the two parties trying to communicate. In effect, the attacker is spying on the interaction between the two parties. In an MITM attack, the two parties involved feel like they are communicating as they normally do. What they do not know is that the person sending the message illicitly modifies or accesses the message before it reaches its destination. Some ways to protect yourself and your organization from MITM attacks are by using strong encryption on access points or by using a virtual private network (VPN).

For example, the attacker can re-route a data exchange. When computers are communicating at low levels of the network layer, the computers might not be able to determine with whom they are exchanging data. If an attacker puts himself between a client and a webpage, a Man-in-the-Middle (MITM) attack occurs. This form of assault comes in many different ways.

For example: To intercept financial login credentials, a fraudulent banking website can be used. Between the user and the real bank webpage, the fake site lies "in the middle."

Typically, these attacks are carried out through a two-step process known as data interception and decryption. Data interception consists of an attacker intercepting a data transfer between a client and a server. The attacker tricks the client and the server into believing that they are exchanging information with each other, while the attacker intercepts the data, creates a connection to the real site, and acts as a proxy to read and insert false information into the communication. The decryption phase is where the intercepted data is unencrypted. This essential step enables the attacker to finally decipher and use the data to their advantage



5) Phishing

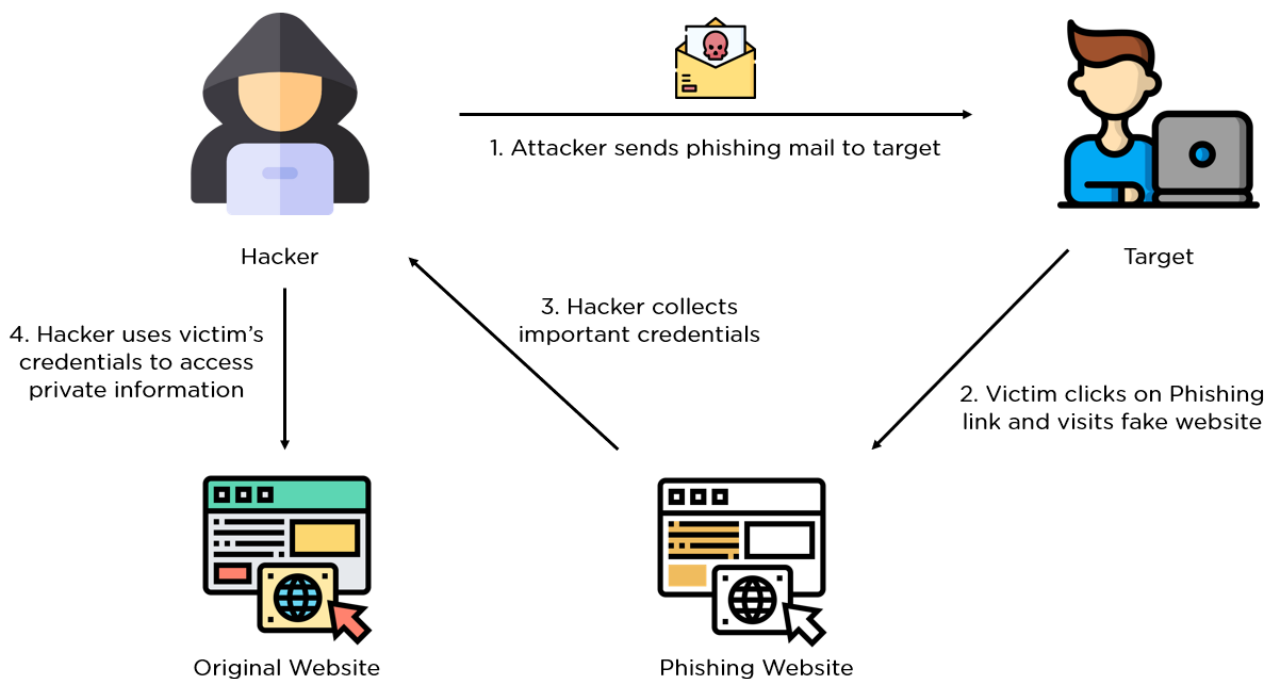
Phishing attacks are fraudulent emails, text messages, phone calls, or websites that seem to be coming from trusted, legitimate sources in an attempt to grab sensitive information from the target. Phishing attacks are designed to trick users into actions like the following

- Downloading malware.
- Sharing sensitive information or personal data (for example, Social Security and credit card numbers, bank account numbers, login credentials).
- Other actions that expose themselves or their organizations to cybercrime.

Successful phishing attacks often lead to identity theft, credit card fraud, ransomware attacks, data breaches and huge financial losses for individuals and corporations.

To execute the attack, the attacker may send a link that brings you to a website that then fools you into downloading malware such as viruses or giving the attacker your private information. In many cases, the target may not realize they have been compromised, which allows the attacker to go after others in the same organization without anyone suspecting malicious activity.

You can prevent phishing attacks from achieving their objectives by thinking carefully about the kinds of emails you open and the links you click on. Pay close attention to email headers, and do not click on anything that looks suspicious. Check the parameters for “Reply-to” and “Return-path.” They need to connect to the same domain presented in the email.



6) SQL Injection:

SQL injection is a technique used to extract user data by injecting web page inputs as statements through SQL commands. Malicious users can use these instructions to manipulate the application's web server. SQL

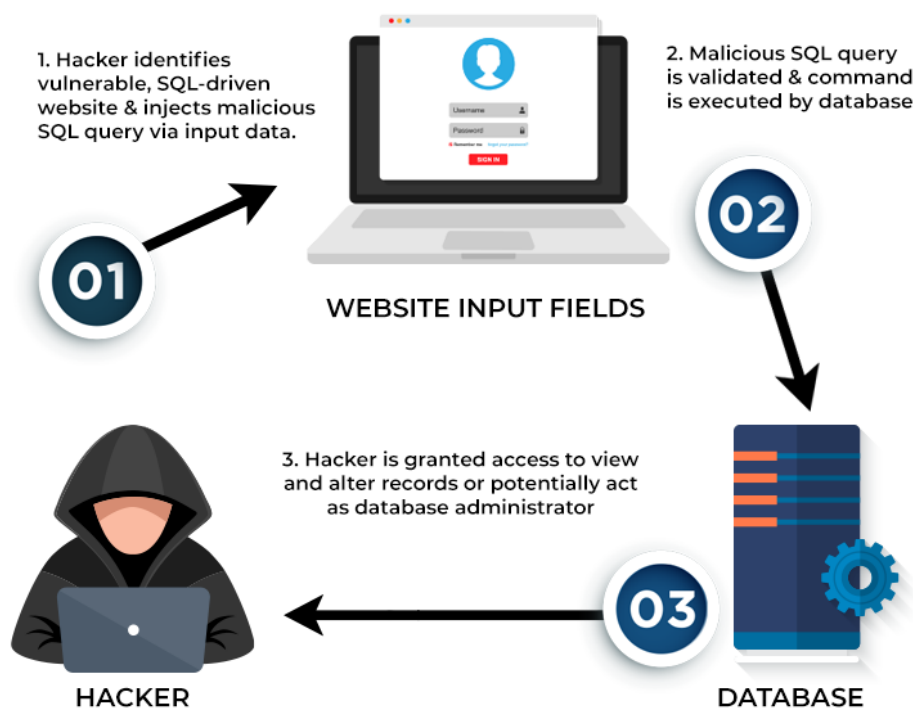
injection is a code injection technique that can compromise your database. SQL injection is one of the most common web hacking techniques. SQL injection is the injection of malicious code into SQL statements via web page input.

An SQL injection attack can be done with the following intentions:

- To dump the whole database of a system,
- To modify the content of the databases, or
- To perform different queries that are not allowed by the application.

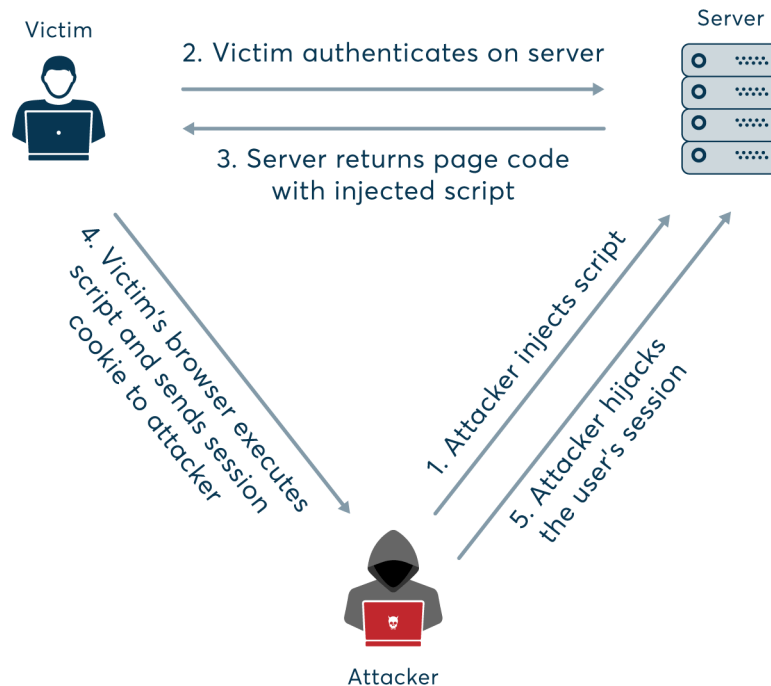
This type of attack works when the applications don't validate the inputs properly, before passing them to an SQL statement. Injections are normally placed in address bars, search fields, or data fields. The easiest way to detect if a web application is vulnerable to an SQL injection attack is to use the " ' " character in a string and see if you get any error.

FUNCTIONING OF AN SQL INJECTION



7) Session Hijacking

Session hijacking is one of multiple types of MITM attacks. The attacker takes over a session between a client and the server. The computer being used in the attack substitutes its Internet Protocol (IP) address for that of the client computer, and the server continues the session without suspecting it is communicating with the attacker instead of the client. This kind of attack is effective because the server uses the client's IP address to verify its identity. If the attacker's IP address is inserted partway through the session, the server may not suspect a breach because it is already engaged in a trusted connection.



To prevent session hijacking, use a VPN to access business-critical servers. This way, all communication is encrypted and an attacker cannot gain access to the secure tunnel created by the VPN.

8) Insider Threat

Sometimes, the most dangerous actors come from within an organization. People within a company's doors pose a special danger because they typically have access to a variety of systems and in some cases, admin privileges that enable them to make critical changes to the system or its security policies.

In addition, people within the organization often have an in-depth understanding of its cybersecurity architecture, as well as how the business reacts to threats. This knowledge can be used to gain access to restricted areas, make changes to security settings, or deduce the best possible time to conduct an attack.

One of the best ways to prevent insider threats in organizations is to limit employees' access to sensitive systems to only those who need them to perform their duties. Also, for the select few who need access, use MFA, which will require them to use at least one thing they know in conjunction with a physical item they have to gain access to a sensitive system.

9) Ransomware

With Ransomware, the victim's system is held hostage until they agree to pay a ransom to the attacker. After the payment has been sent, the attacker then provides instructions regarding how the target can regain control of their computer. The name "ransomware" is appropriate because the malware demands a ransom from the victim.

In a ransomware attack, the target downloads ransomware, either from a website or from within an email attachment. The malware is written to exploit vulnerabilities that have not been addressed by either the system's manufacturer or the IT team. The ransomware then encrypts the target's workstation. At times, ransomware can be used to attack multiple parties by denying access to either several computers or a central server essential to business operations.

Affecting multiple computers is often accomplished by not initiating systems captivation until days or even weeks after the malware's initial penetration. The malware can send AUTORUN files that go from one system to another via the internal network or Universal Serial Bus (USB) drives that connect to multiple computers. Then, when the attacker initiates the encryption, it works on all the infected systems simultaneously.

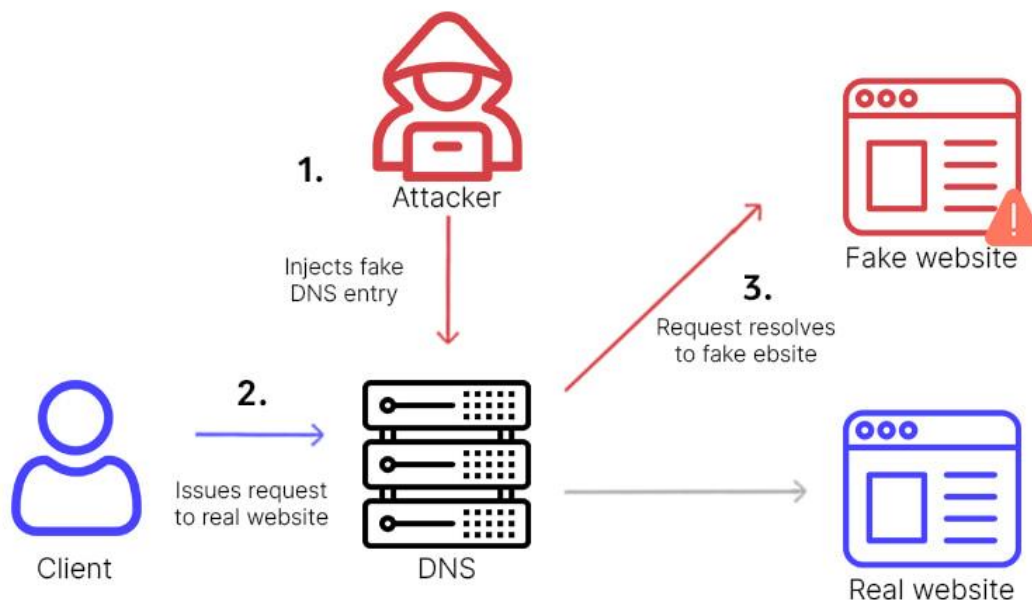
10) DNS Spoofing

DNS Spoofing is a type of computer attack wherein a user is forced to navigate to a fake website disguised to look like a real one, to divert traffic or steal the credentials of the users. Spoofing attacks can go on for a long period without being detected and can cause serious security issues.

In a DNS spoofing attack, the attacker takes advantage of the fact that the user thinks the site they are visiting is legitimate. This gives the attacker the ability to commit crimes in the name of an innocent company, at least from the perspective of the visitor.

Domain Name Server (DNS) resolves the alphabetical domain names like `www.example.com` into respective IP addresses that are used for locating and communicating between nodes on the Internet. DNS spoofing is done by replacing the IP addresses stored in the DNS server with the ones under the control of the attacker. Once it is done, whenever users try to go to a particular website, they get directed to the false websites placed by the attacker in the spoofed DNS server.

To prevent DNS spoofing, make sure your DNS servers are kept up-to-date. Attackers aim to exploit vulnerabilities in DNS servers, and the most recent software versions often contain fixes that close known vulnerabilities.



1.4 TYPES OF CRYPTOGRAPHY

1.4.1 Introduction to Cryptography

Cryptography is a technique of securing information and communications through the use of codes so that only those people for whom the information is intended can understand and process it. Thus, preventing unauthorized access to information. The prefix “crypt” means “hidden” and the suffix “graphy” means “writing”. In Cryptography, the techniques that are used to protect information are obtained from mathematical concepts and a set of rule-based calculations known as algorithms to convert messages in ways that make it hard to decode them. These algorithms are used for cryptographic key generation, digital signing and verification to protect data privacy, web browsing on the internet and to protect confidential transactions such as credit card and debit card transactions.

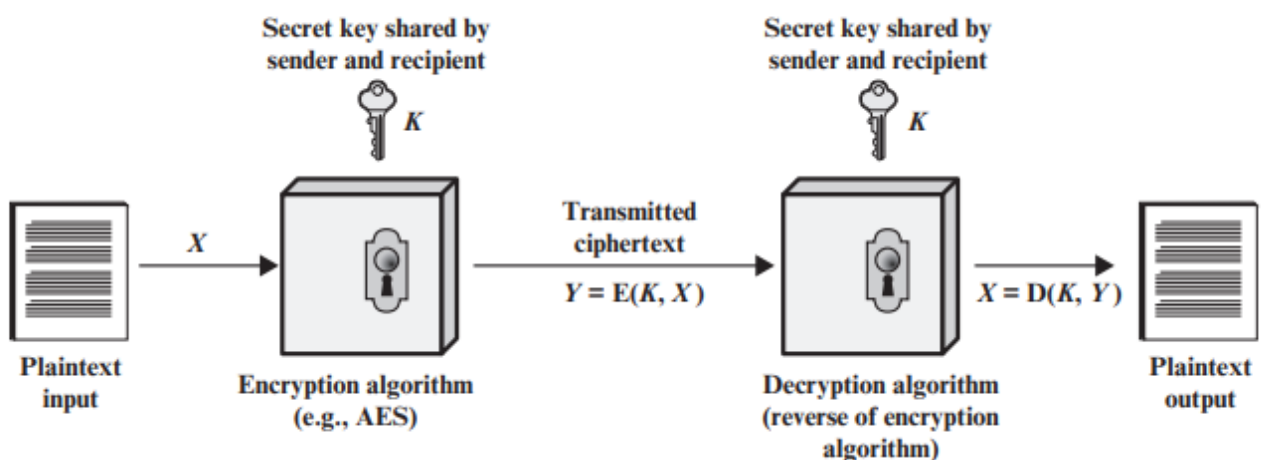
Cryptographic systems are characterized along three independent dimensions:

- 1) The type of operations used for transforming plaintext to ciphertext (Substitution and Transposition).
- 2) The number of keys used (Symmetric Key and Asymmetric Key).
- 3) The way in which the plaintext is processed (Block Cipher and Stream Cipher).

Features of Cryptography:

- 1) Confidentiality
- 2) Integrity
- 3) Non-repudiation
- 4) Authentication

1.4.2 Symmetric Cipher Model



A symmetric cipher scheme consists of 5 main components:

- 1) **Plain Text:** The original message, before being transformed, is called plaintext.
- 2) **Encryption Algorithm:** The process of transforming the plaintext into ciphertext is known as enciphering or encryption. It takes plain text and key value as input to produce cipher text. The encryption algorithm performs various substitutions and transformations on the plaintext.
- 3) **Secret Key:** The secret key is also input to the encryption algorithm. The key is a value independent of the plaintext and the algorithm. The algorithm will produce a different output depending on the specific key being used at the time. The exact substitutions and transformations performed by the algorithm depend on the key.
- 4) **Cipher Text:** The original message after being transformed into a non-readable message is called ciphertext. This is the scrambled message produced as output. It depends on the plaintext and the secret key. For a given message, two different keys will produce two different ciphertexts.
- 5) **Decryption Algorithm:** The process of transforming the cipher text back into plain text is known as deciphering or decryption. It takes cipher text and key value as input to produce plain text back.

1.4.3 Cryptanalysis

Typically, the objective of attacking an encryption system is to recover the key in use rather than simply to recover the plaintext of a single ciphertext. There are two general approaches to attacking a conventional encryption scheme:

- 1) **Cryptanalysis:** Cryptanalytic attacks rely on the nature of the algorithm plus perhaps some knowledge of the general characteristics of the plaintext or even some sample plaintext ciphertext pairs. This type of attack exploits the characteristics of the algorithm to attempt to deduce a specific plaintext or to deduce the key being used.
- 2) **Brute-force attack:** The attacker tries every possible key on a piece of ciphertext until an intelligible translation into plaintext is obtained. On average, half of all possible keys must be tried to achieve success.

1.4.4 Types of Cryptography

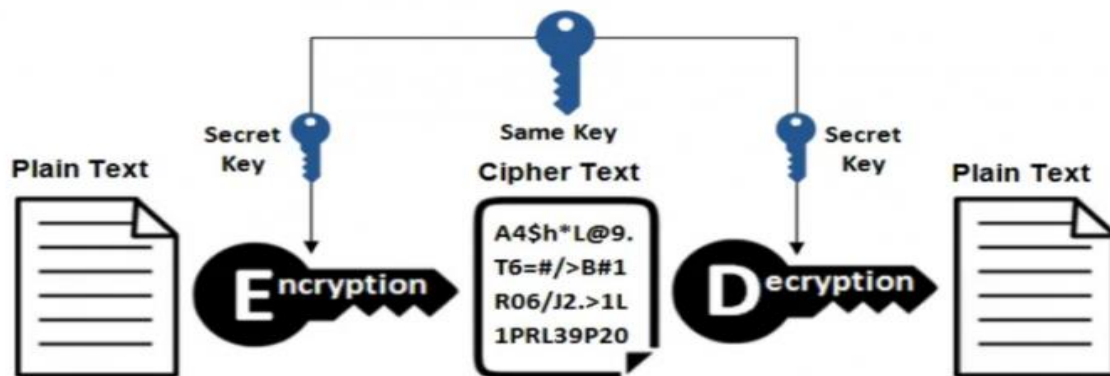
There are three types of Cryptography:

- 1) Symmetric Key Cryptography
- 2) Asymmetric Key Cryptography
- 3) Hash Function

Symmetric Key Cryptography:

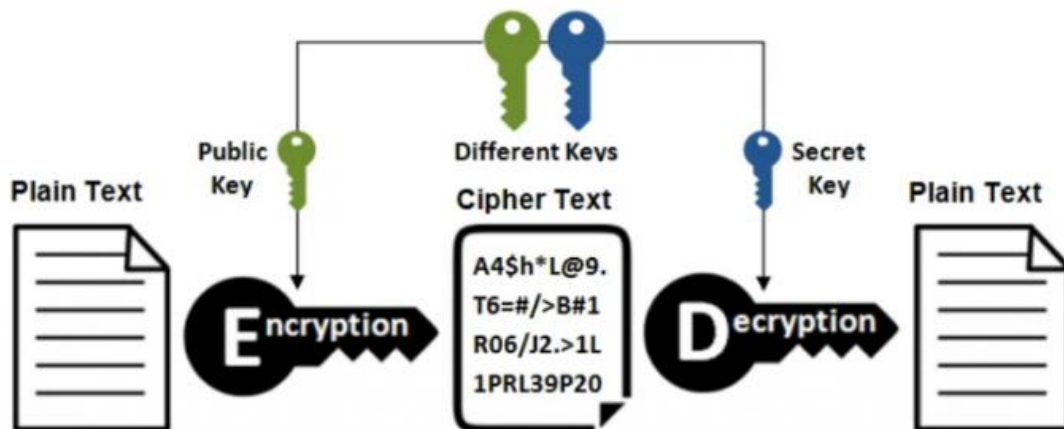
Symmetric key cryptography is also known as secret-key cryptography, and in this type of cryptography, you can use only a single key. The sender and the receiver can use that single key to encrypt and decrypt a message. Because there is only one key for encryption and decryption, the symmetric key system has one major

disadvantage: the two parties must exchange the key securely. The most popular symmetric key cryptography systems are Data Encryption System (DES), Advanced Encryption System (AES), Blowfish.



Asymmetric Key Cryptography:

Asymmetric key cryptography is also known as public key cryptography and it employs the use of two keys. This cryptography differs from and is more secure than symmetric key cryptography. In this system, each user encrypts and decrypts using two keys or a pair of keys (private key and public key). Each user keeps the private key secret and the public key is distributed across the network so that anyone can use those public keys to send a message to any other user. You can use any of those keys to encrypt the message and can use the remaining key for decryption. The most popular symmetric key cryptography system is DSA and RSA.



Hash Function:

It is a type of cryptography in which an algorithm followed by a hash function takes an arbitrary length of the message as input and returns a fixed length of the output. It is also referred to as a mathematical equation because it uses numerical values as input to generate the hash message. This method does not require a key because it operates in a one-way scenario. Each round of hashing operations considers input as an array of the most recent block and generates the last round of activity as output. Commonly used hash algorithms include: Message Digest 5 (MD5), SHA (Secure Hash Algorithm)

